Report ID: CSD-RT-082

Assessment Date: April 17-21, 2026

Report Date: April 23, 2026

Executing Team: Red Team in the Cyber Security Department

Target: inf-tele-karbala.vercel.app

⚠ OVERALL RISK LEVEL: CRITICAL

1. Executive Summary

This report is the product of a comprehensive and thorough security assessment. The findings reveal a complete collapse of the security architecture of the Karbala Telecommunications Management System. An unauthorized actor gained access to all system access keys and exfiltrated the sensitive data of 348 employees, including salaries, bank account numbers (IBAN), and plaintext (unhashed) passwords. The system is currently exposed to full unauthorized access and control.

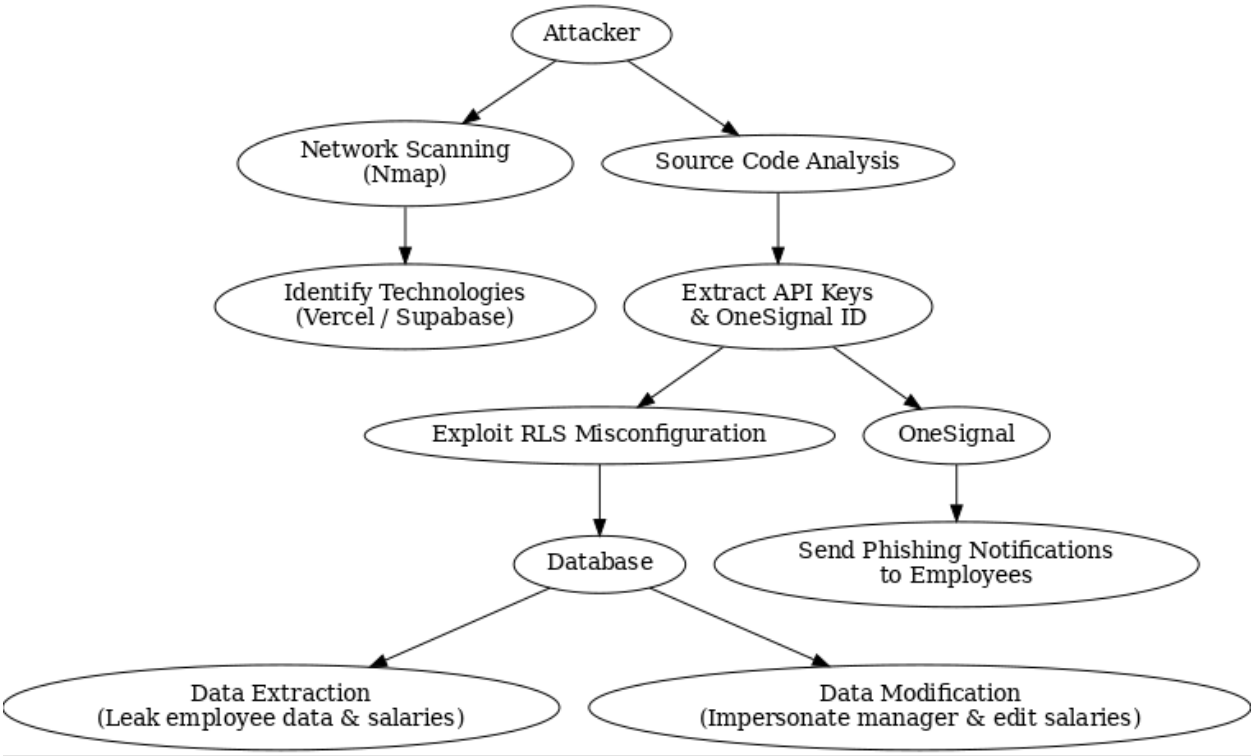
2. Full Attack Vector Methodology

Attack Flow

The attack followed a sequential, multi-stage methodology:

- **Reconnaissance Phase:** Analysis of JavaScript (JS) bundle files to extract embedded secrets.
- **Extraction Phase:** Full database dump by exploiting the absence of Row Level Security (RLS).
- **Privilege Escalation Phase:** Login to User, Supervisor, and Developer panels using plaintext credentials exposed in the leak.

Attack Flow Diagram



3. Detailed Technical Findings & Evidence

3.1 Hardcoded Secrets & Information Leakage

Critical environment variables and API keys were found hardcoded directly inside the frontend JavaScript bundle (index-D05SJKk2.js). This constitutes a severe violation of the principle of secrets management.

```
SUPABASE_URL:    "https://jvnjkqxpnhridlbczkgw.supabase.co"
SUPABASE_ANON_KEY: "sb_publishable_WSFpLJv1U6t-VezOuSWwZw_Dr8PvoyS"
ONESIGNAL_APP_ID:  "beae0757-7abe-46a8-b223-8f6c65e47fb5"
```

3.2 Global RLS Bypass (Unauthorized Database Access)

The system fails to enforce Row Level Security (RLS) on Supabase tables. Using the leaked keys, any external attacker can execute full CRUD (Create, Read, Update, Delete) operations on the 'profiles' and 'financial_records' tables without any authentication.

Proof-of-Concept (PoC) Command — fetches all 348 records:

```
curl -X GET "https://jvnjkqxpnhridlbczkgw.supabase.co/rest/v1/profiles?select=*"  \
  -H "apikey: sb_publishable_WSFpLJv1U6t-VezOuSWwZw_Dr8PvoyS" \
  -H "Authorization: Bearer sb_publishable_WSFpLJv1U6t-VezOuSWwZw_Dr8PvoyS"
```

3.3 Plaintext Password Storage

Passwords are stored in the database without any hashing or encryption. This means that anyone with database access can immediately use credentials for identity theft or further attacks.

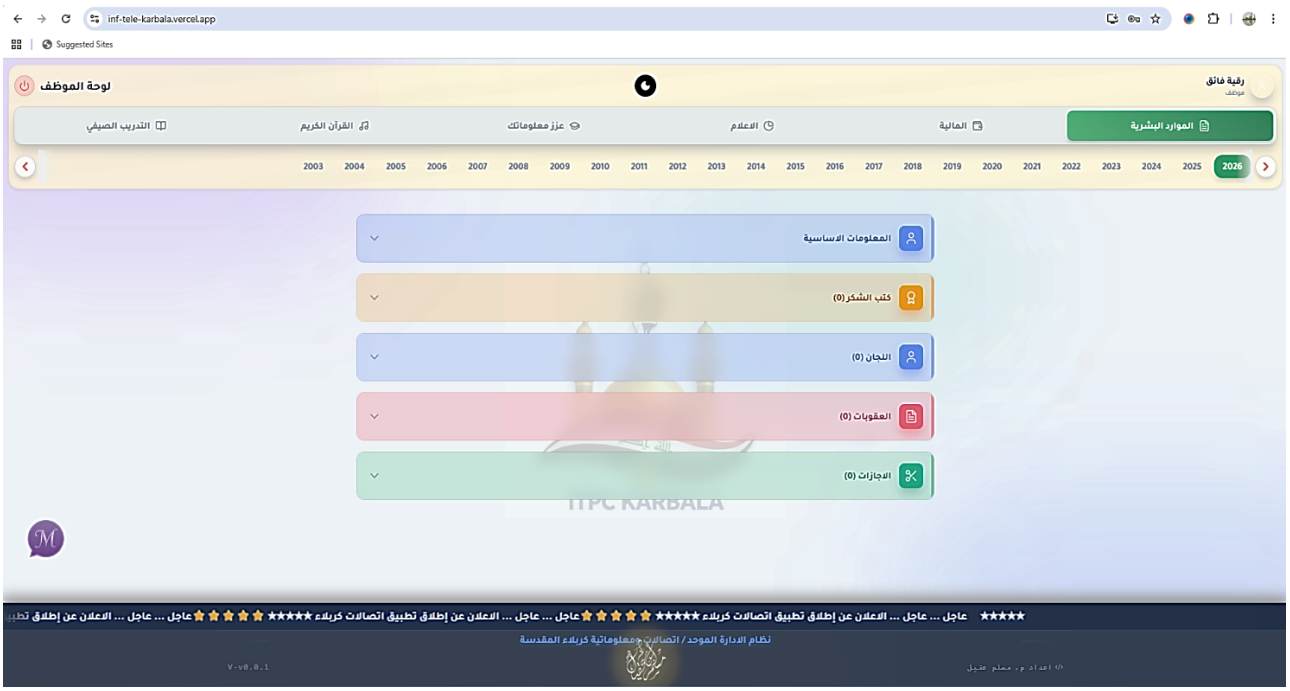
Sample of leaked credentials (from confirmed records):

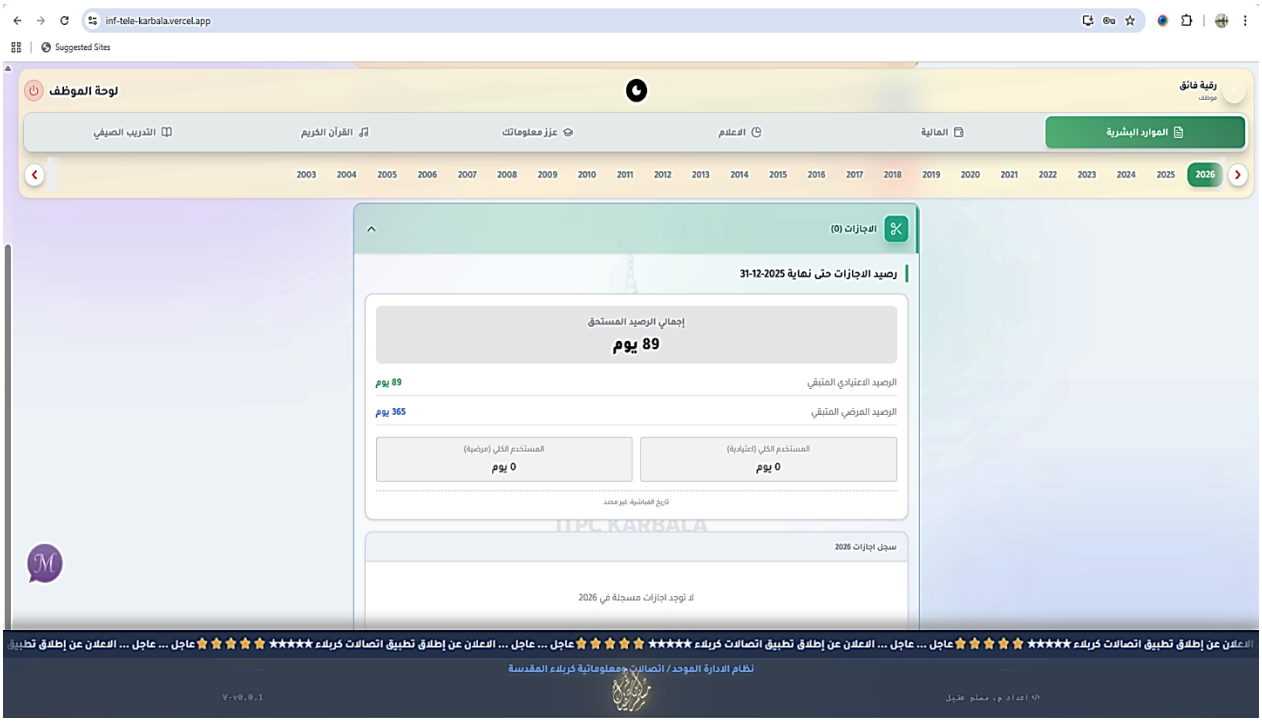
Full Name	Username	Password (Leaked)	Role
مسلم عقيل عبدالحسن	مسلم عقيل	654321	Developer
حيدر هاتف عبدالحمزة	حيدر هاتف	106521	User
جلنار زهير	جلنار زهير	123456	User

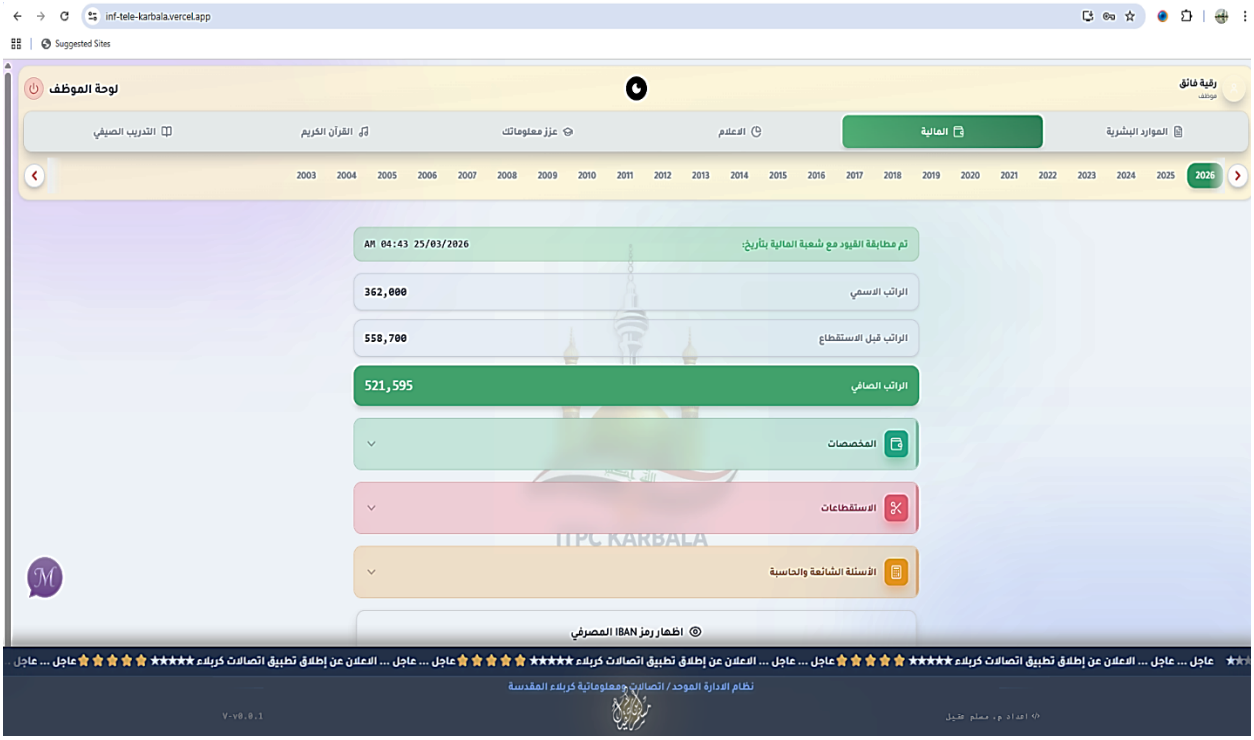
4. Privilege Escalation Levels Achieved

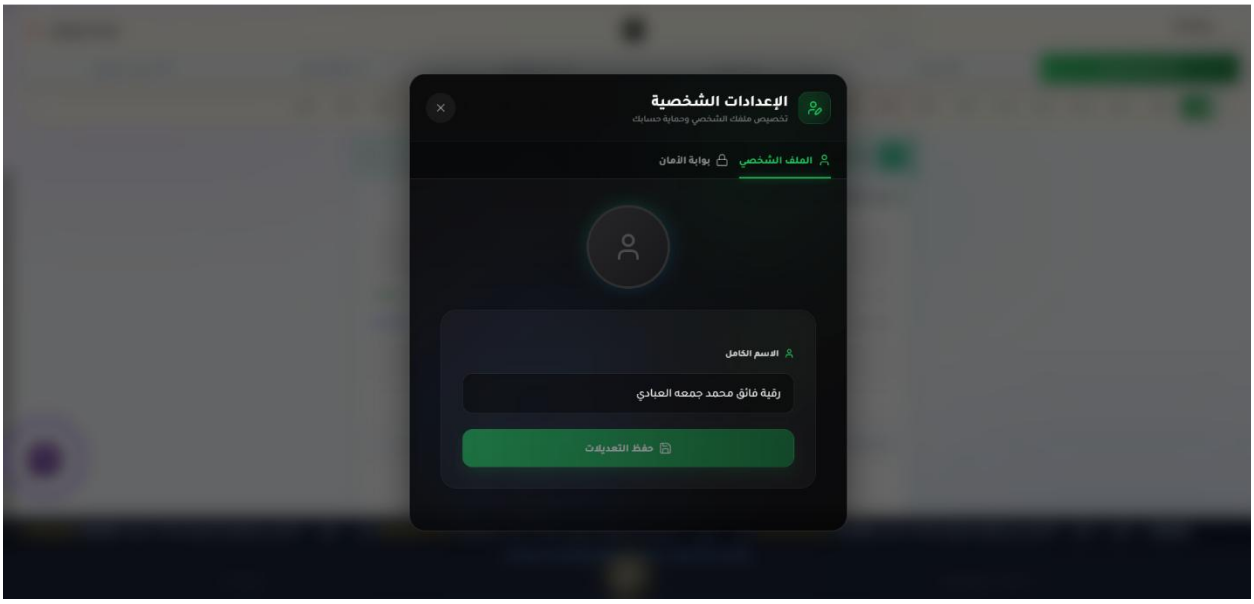
Full access was successfully verified across all system interface levels:

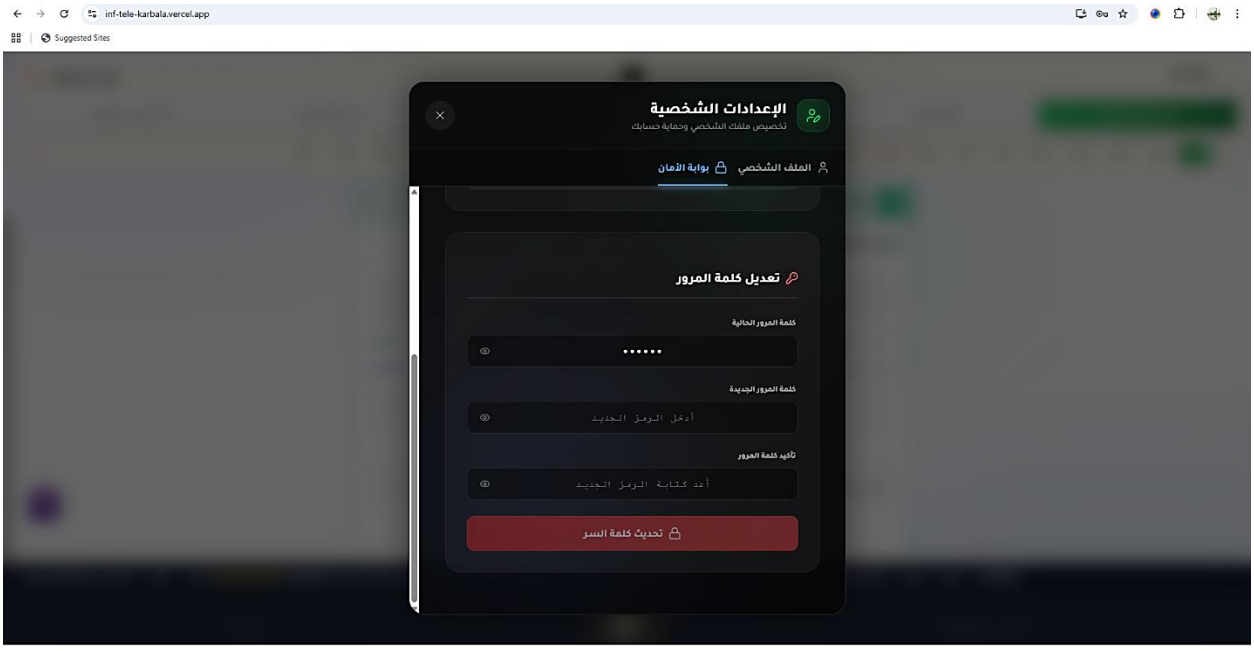
• **User Level:** Access to personal profiles, leave requests, and individual financial data.



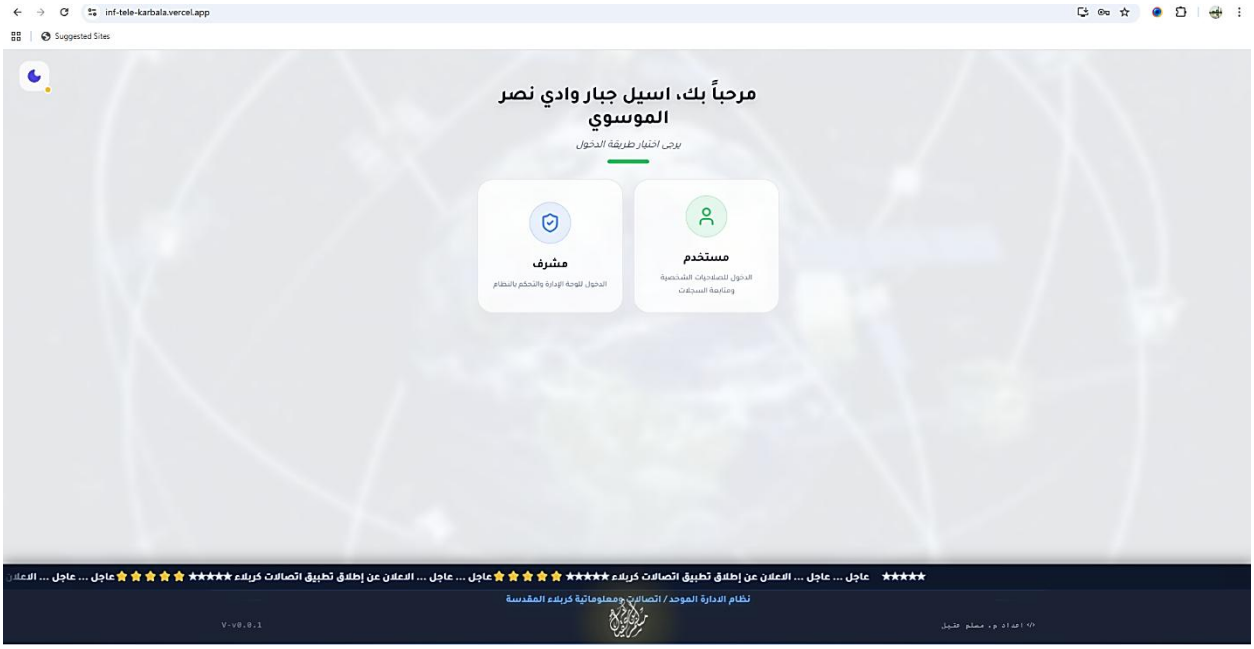

inf-tele-karbala.vercel.app
Suggested Sites
لوحة الموظف
رقية فائق
موظف
الموارد البشرية
المالية
الاعلام
عزز معلوماتك
القرآن الكريم
التدريب الصيفي
2026
الاجازات (0)
رصيد الاجازات حتى نهاية 31-12-2025
إجمالي الرصيد المستحق
89 يوم
الرصيد الاعتيادي المتبقي
89 يوم
الرصيد المرضي المتبقي
365 يوم
المستخدم الكلي (اعتيادية)
0 يوم
المستخدم الكلي (مرضية)
0 يوم
تاريخ المباشرة غير محدد
سجل اجازات 2026
لا توجد اجازات مسجلة في 2026
ITPC KARBALA
نظام الادارة الموحد / اتصالات ومعلوماتية كربلاء المقدسة
V-v0.0.1
اعداد م. معلم عقيل

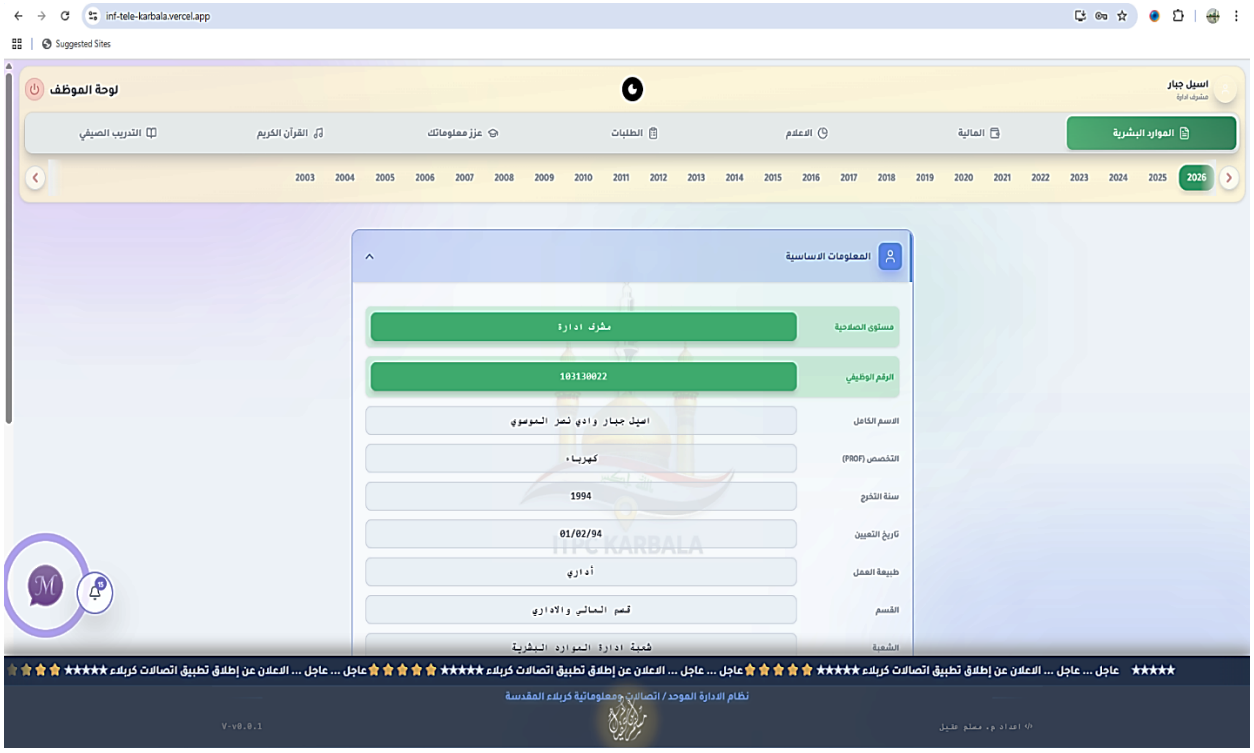

inf-tele-karbala.vercel.app
Suggested Sites
لوحة الموظف
رقية فائق
موظف
الموارد البشرية
المالية
الاعلام
عزز معلوماتك
القرآن الكريم
التدريب الصيفي
2026
تم مطابقة القيود مع شعبة المالية بتأريخ:
AM 04:43 25/03/2026
الراتب الاسمي
362,000
الراتب قبل الاستقطاع
558,700
الراتب الصافي
521,595
المخصصات
الاستقطاعات
الأسئلة الشائعة والحاسبة
اظهار رمز IBAN المصرفي
ITPC KARBALA
نظام الادارة الموحد / اتصالات ومعلوماتية كربلاء المقدسة
V-v0.0.1
اعداد م. معلم عقيل

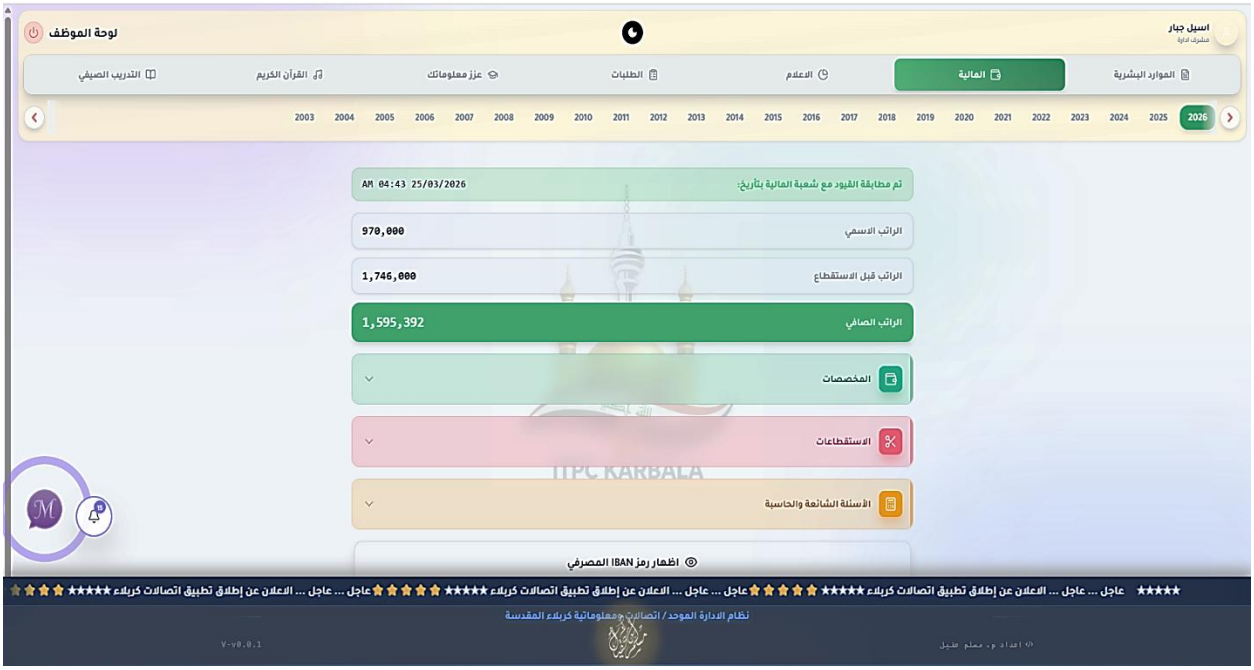

الإعدادات الشخصية
تخصيص ملفك الشخصي وحماية حسابك
الملف الشخصي
بوابة الأمان
الاسم الكامل
رقية فائق محمد جمعه العبادي
حفظ التعديلات

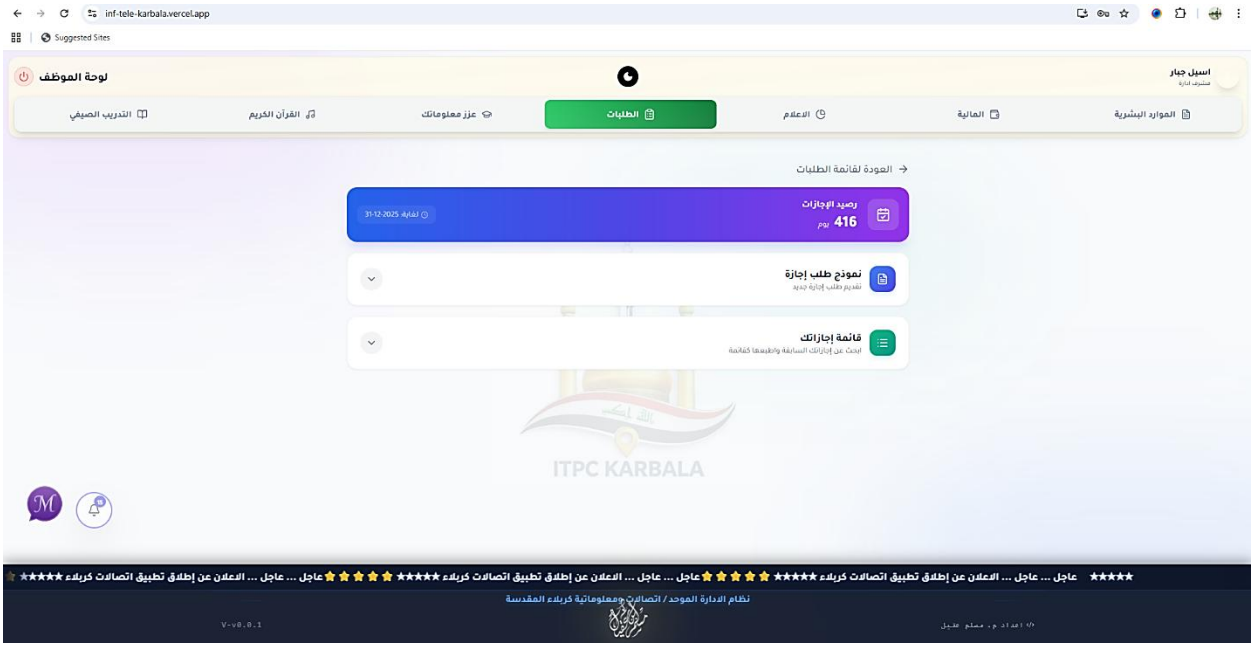

inf-tele-karbala.vercel.app
Suggested Sites
الإعدادات الشخصية
تخصيص ملفك الشخصي وحماية حسابك
الملف الشخصي
بوابة الأمان
تعديل كلمة المرور
كلمة المرور الحالية
كلمة المرور الجديدة
أدخل الرمز الجديد
تأكيد كلمة المرور
أعد كتابة الرمز الجديد
تحديث كلمة السر

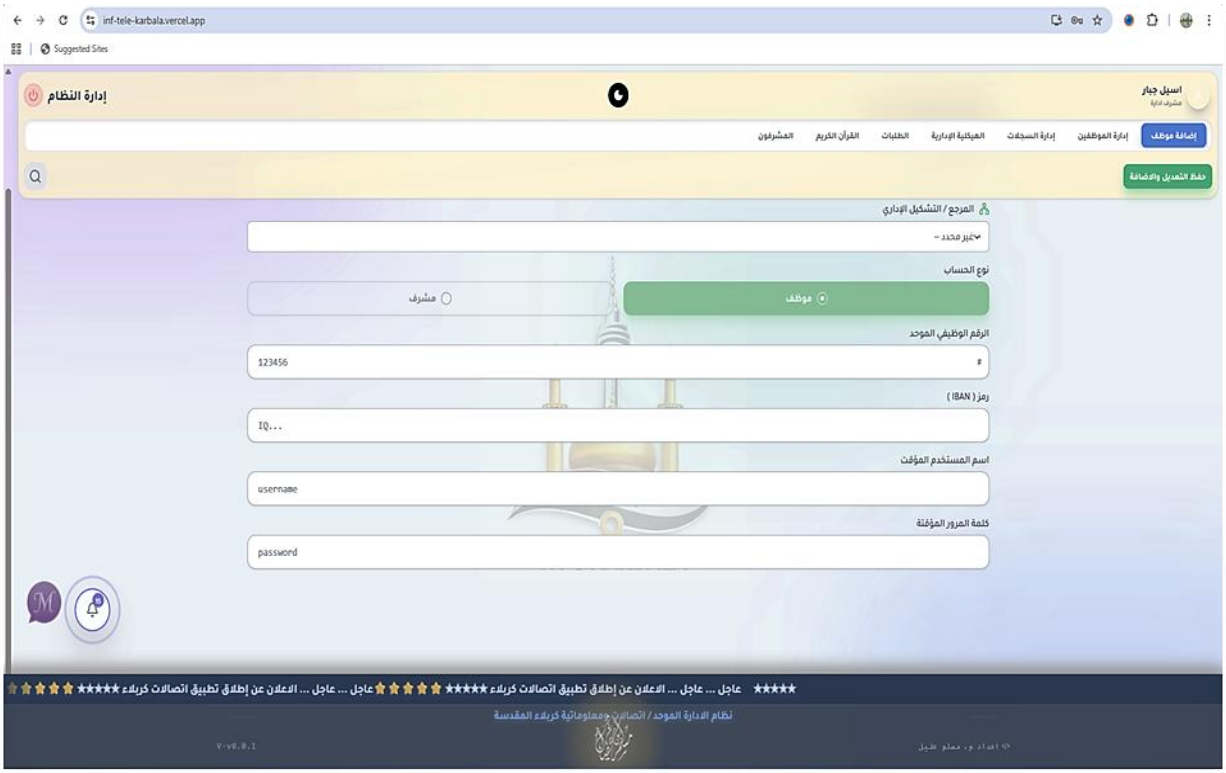
• **Supervisor Level:** Access to departmental overviews, salary management, and approval workflows.

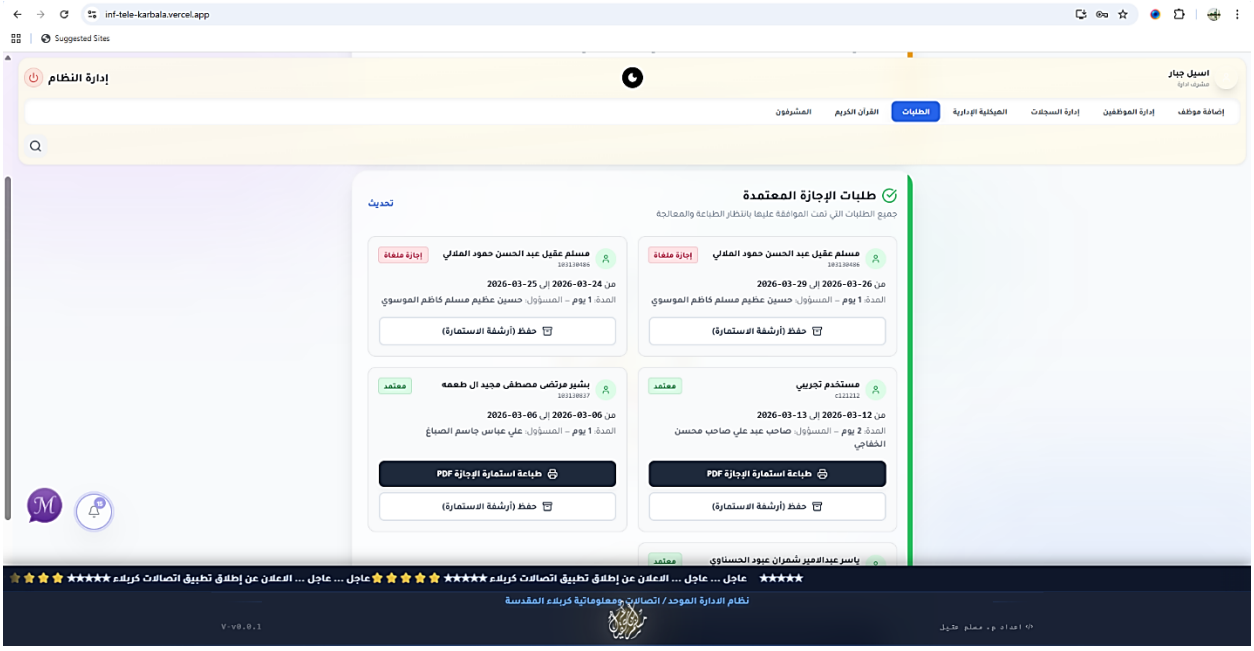


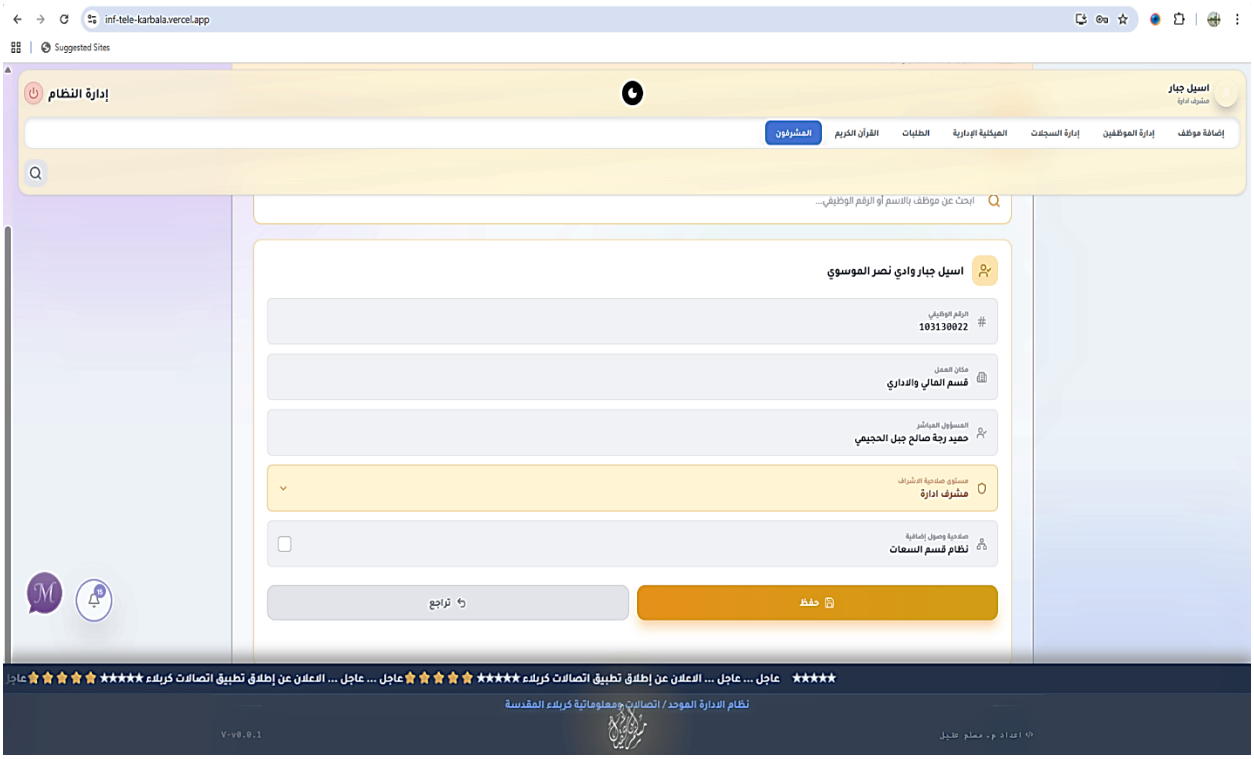


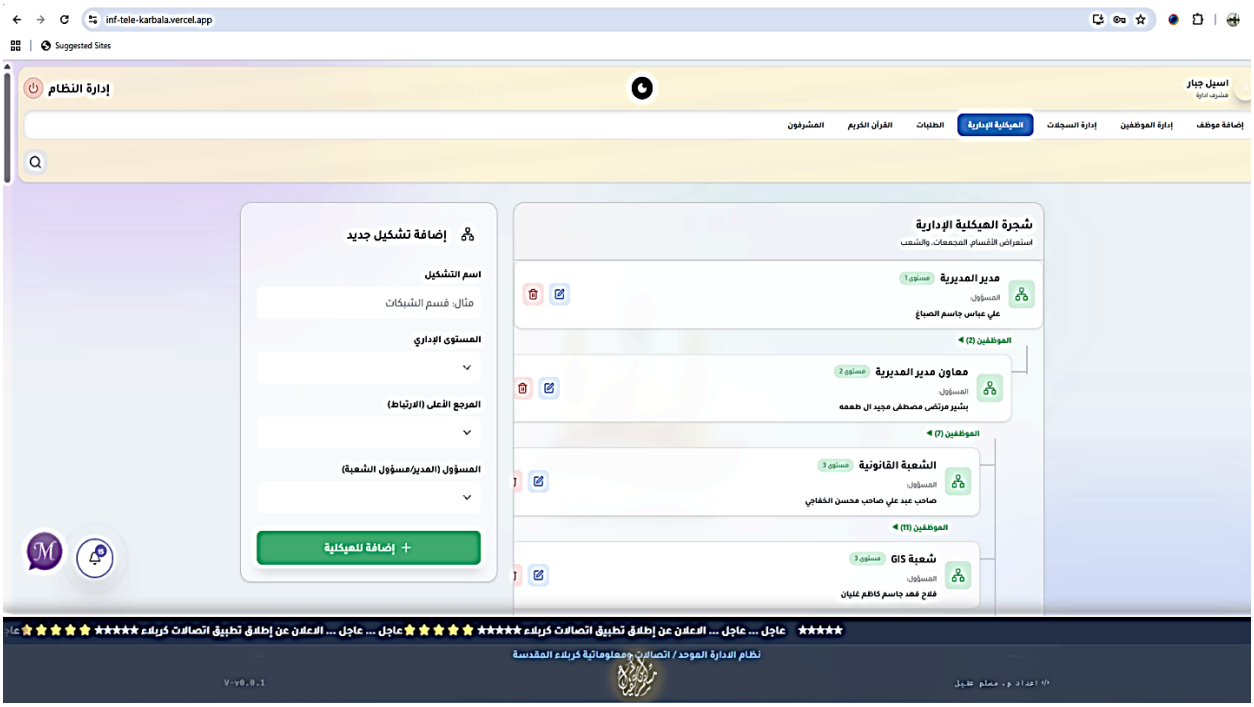

لوحة الموظف
اسيل جبار
الموارد البشرية
المالية
الاعلام
الطلبات
عزز معلوماتك
القرآن الكريم
التدريب الصيفي
2026 2025 2024 2023 2022 2021 2020 2019 2018 2017 2016 2015 2014 2013 2012 2011 2010 2009 2008 2007 2006 2005 2004 2003
تم مطابقة القيود مع شعبة المالية بتأريخ: AM 04:43 25/03/2026
الراتب الاسمي 970,000
الراتب قبل الاستقطاع 1,746,000
الراتب الصافي 1,595,392
المخصصات
الاستقطاعات
الأسئلة الشائعة والحاسبة
اظهار رمز IBAN المصرفي
ITPC KARBALA
عاجل ... عاجل ... الاعلان عن إطلاق تطبيق اتصالات كربلاء
نظام الادارة الموحد / اتصالات ومعلوماتية كربلاء المقدسة


inf-tele-karbala.vercel.app
Suggested Sites
لوحة الموظف
اسيل جبار
الموارد البشرية
المالية
الاعلام
الطلبات
عزز معلوماتك
القرآن الكريم
التدريب الصيفي
العودة لقائمة الطلبات
رصيد الاجازات
416 يوم
نموذج طلب إجازة
تقديم طلب إجازة جديد
قائمة إجازاتك
ابحث عن إجازاتك السابقة واطبعها كقائمة
ITPC KARBALA
عاجل ... عاجل ... الاعلان عن إطلاق تطبيق اتصالات كربلاء
نظام الادارة الموحد / اتصالات ومعلوماتية كربلاء المقدسة

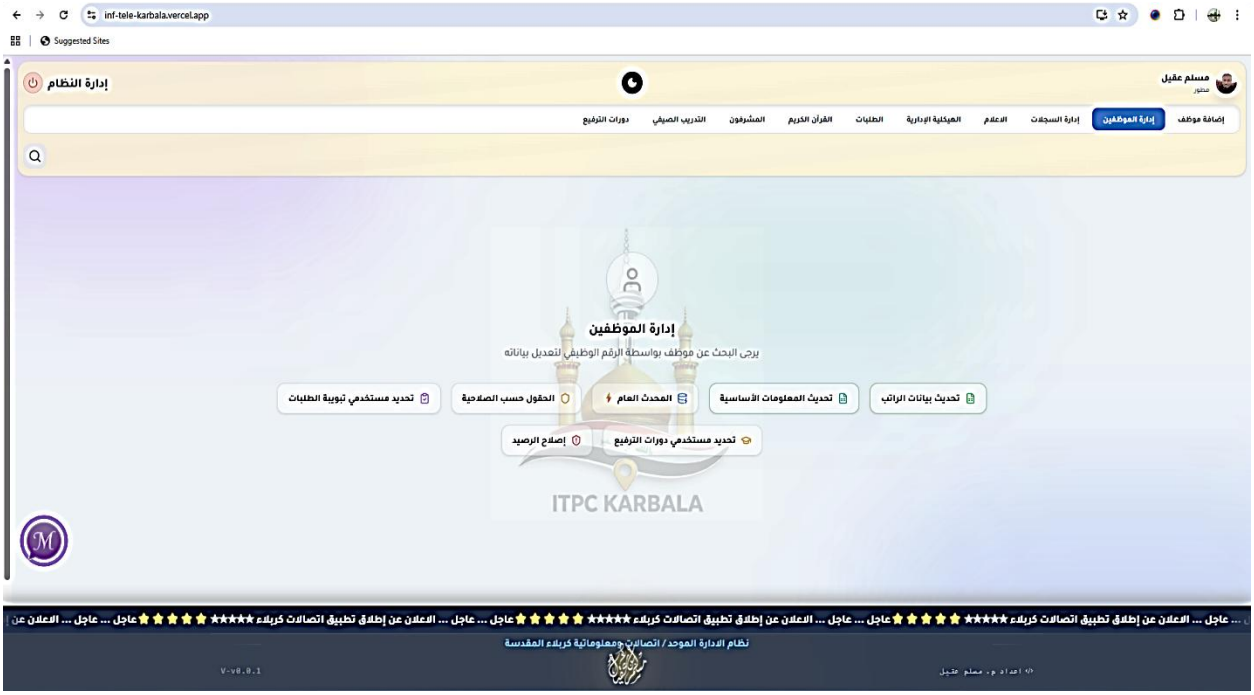

inf-tele-karbala.vercel.app
Suggested Sites
إدارة النظام
اسيل جبار
مشرف ادارة
إضافة موظف
إدارة الموظفين
إدارة السجلات
الهيكلية الإدارية
الطلبات
القرآن الكريم
المشرفون
حفظ التعديل والاضافة
المرجع / التشكيل الإداري
-غير محدد-
نوع الحساب
موظف
مشرف
الرقم الوظيفي الموحد
123456
رمز (IBAN)
IQ...
اسم المستخدم المؤقت
username
كلمة المرور المؤقتة
password
عاجل ... عاجل ... الاعلان عن إطلاق تطبيق اتصالات كربلاء
نظام الادارة الموحد / اتصالات ومعلوماتية كربلاء المقدسة
V-v0.0.1

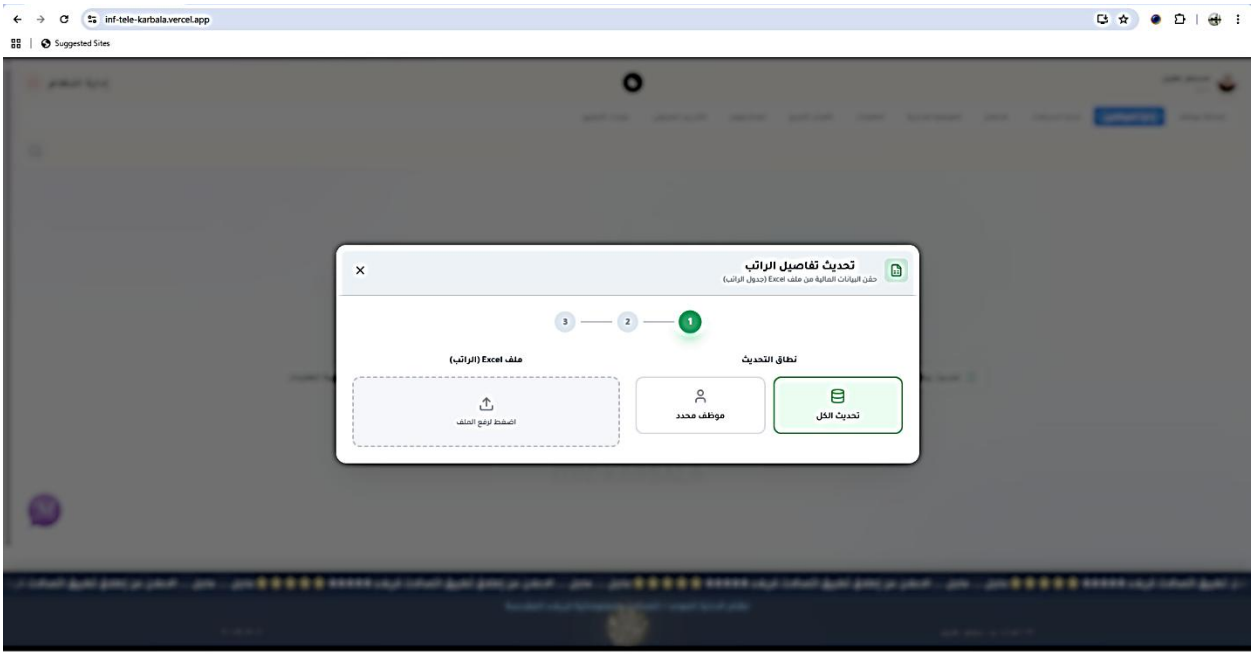

inf-tele-karbala.vercel.app
Suggested Sites
إدارة النظام
اسيل جبار
مشرف ادارة
إضافة موظف
إدارة الموظفين
إدارة السجلات
الهيكلية الإدارية
الطلبات
القرآن الكريم
المشرفون
طلبات الإجازة المعتمدة
جميع الطلبات التي تمت الموافقة عليها بانتظار الطباعة والمعالجة
تحديث
مسلم عقيل عبد الحسن حمود الملالي
إجازة ملغاة
من 2026-03-26 إلى 2026-03-29
المدة: 1 يوم – المسؤول: حسين عظيم مسلم كاظم الموسوي
حفظ (أرشفة الاستمارة)
مسلم عقيل عبد الحسن حمود الملالي
إجازة ملغاة
من 2026-03-24 إلى 2026-03-25
المدة: 1 يوم – المسؤول: حسين عظيم مسلم كاظم الموسوي
حفظ (أرشفة الاستمارة)
مستخدم تجريبي
معتمد
من 2026-03-12 إلى 2026-03-13
المدة: 2 يوم – المسؤول: صاحب عبد علي صاحب محسن الخفاجي
طباعة استمارة الإجازة PDF
حفظ (أرشفة الاستمارة)
بشير مرتضى مصطفى مجيد ال طعمه
معتمد
من 2026-03-06 إلى 2026-03-06
المدة: 1 يوم – المسؤول: علي عباس جاسم الصباغ
طباعة استمارة الإجازة PDF
حفظ (أرشفة الاستمارة)
ياسر عبدالامير شمران عبود الحسناوي
معتمد
عاجل ... عاجل ... الاعلان عن إطلاق تطبيق اتصالات كربلاء
نظام الادارة الموحد / اتصالات ومعلوماتية كربلاء المقدسة
V-v0.0.1

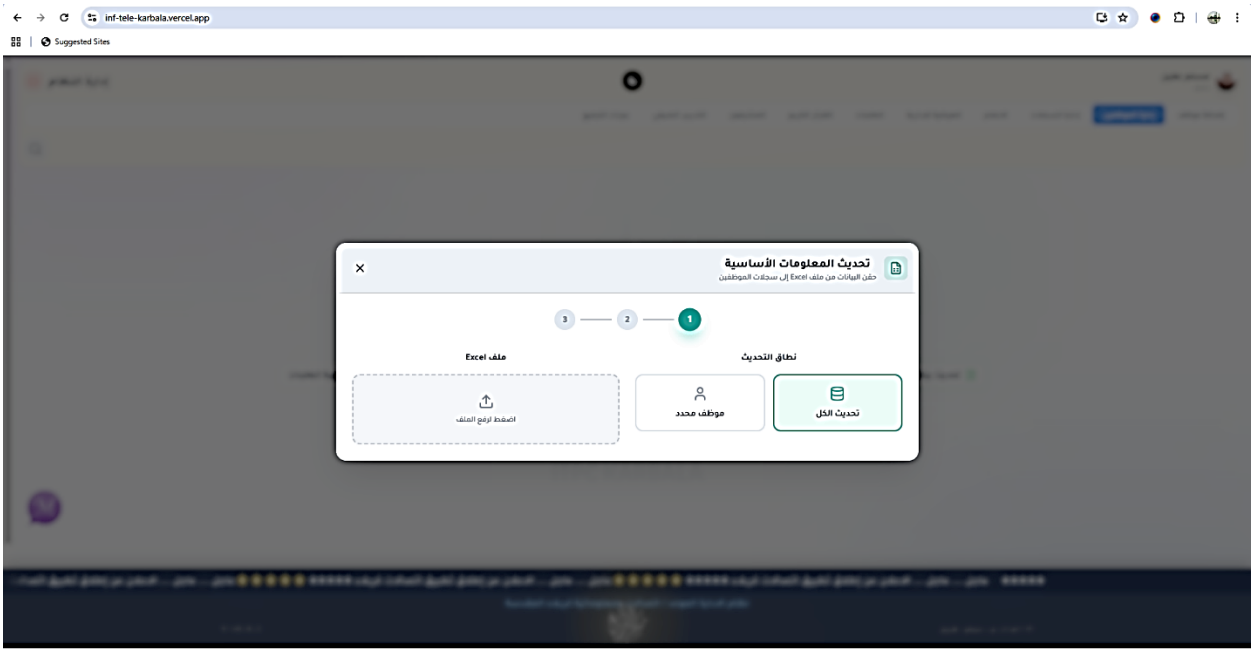

inf-tele-karbala.vercel.app
Suggested Sites
إدارة النظام
اسيل جبار
مشرف ادارة
إضافة موظف
إدارة الموظفين
إدارة السجلات
الهيكلية الإدارية
الطلبات
القرآن الكريم
المشرفون
ابحث عن موظف بالاسم أو الرقم الوظيفي...
اسيل جبار وادي نصر الموسوي
الرقم الوظيفي
103130022
مكان العمل
قسم المالي والاداري
المسؤول المباشر
حميد رجة صالح جبل الحجيمي
مستوى صلاحية الاشراف
مشرف ادارة
صلاحية وصول إضافية
نظام قسم السعات
تراجع
حفظ
عاجل ... عاجل ... الاعلان عن إطلاق تطبيق اتصالات كربلاء
نظام الادارة الموحد / اتصالات ومعلوماتية كربلاء المقدسة
V-v0.0.1
اعداد م. مسلم عقيل

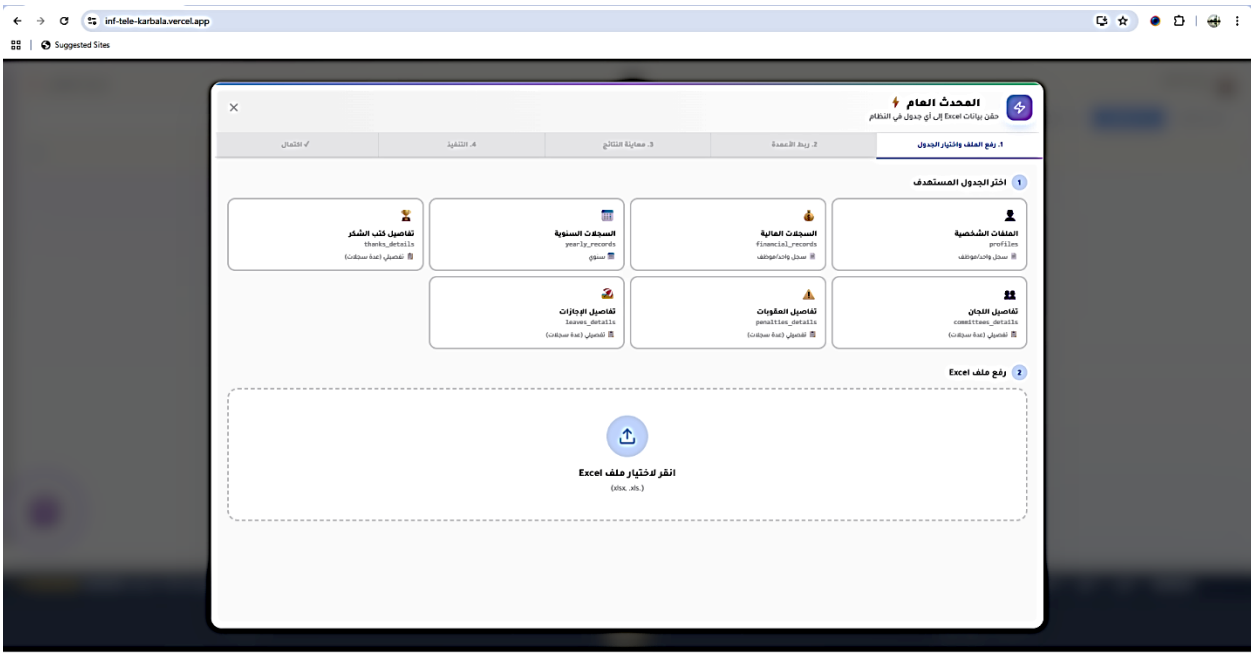

inf-tele-karbala.vercel.app
Suggested Sites
إدارة النظام
اسيل جبار
مشرف ادارة
إضافة موظف
إدارة الموظفين
إدارة السجلات
الهيكلية الإدارية
الطلبات
القرآن الكريم
المشرفون
إضافة تشكيل جديد
اسم التشكيل
مثال: قسم الشبكات
المستوى الإداري
المرجع الأعلى (الارتباط)
المسؤول (المدير/مسؤول الشعبة)
+ إضافة للهيكلية
شجرة الهيكلية الإدارية
استعراض الأقسام، المجمعات، والشعب
مدير المديرية
مستوى 1
المسؤول:
علي عباس جاسم الصباغ
الموظفين (2)
معاون مدير المديرية
مستوى 2
المسؤول:
بشير مرتضى مصطفى مجيد ال طعمه
الموظفين (7)
الشعبة القانونية
مستوى 3
المسؤول:
صاحب عبد علي صاحب محسن الخفاجي
الموظفين (11)
شعبة GIS
مستوى 3
المسؤول:
فلاح فهد جاسم كاظم غليان
عاجل ... عاجل ... الاعلان عن إطلاق تطبيق اتصالات كربلاء
نظام الادارة الموحد / اتصالات ومعلوماتية كربلاء المقدسة
V-v0.0.1
اعداد م. مسلم عقيل

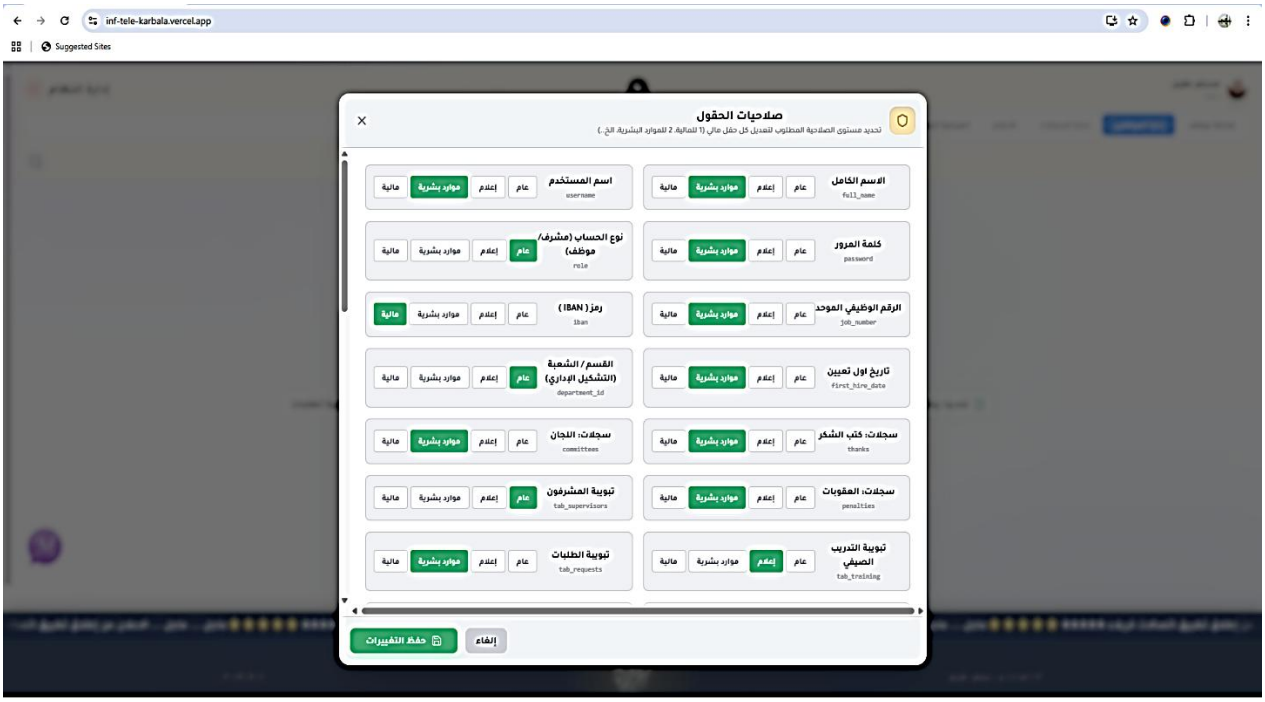
• **Developer Level:** Access to system settings, push notification triggers, and database schema controls.

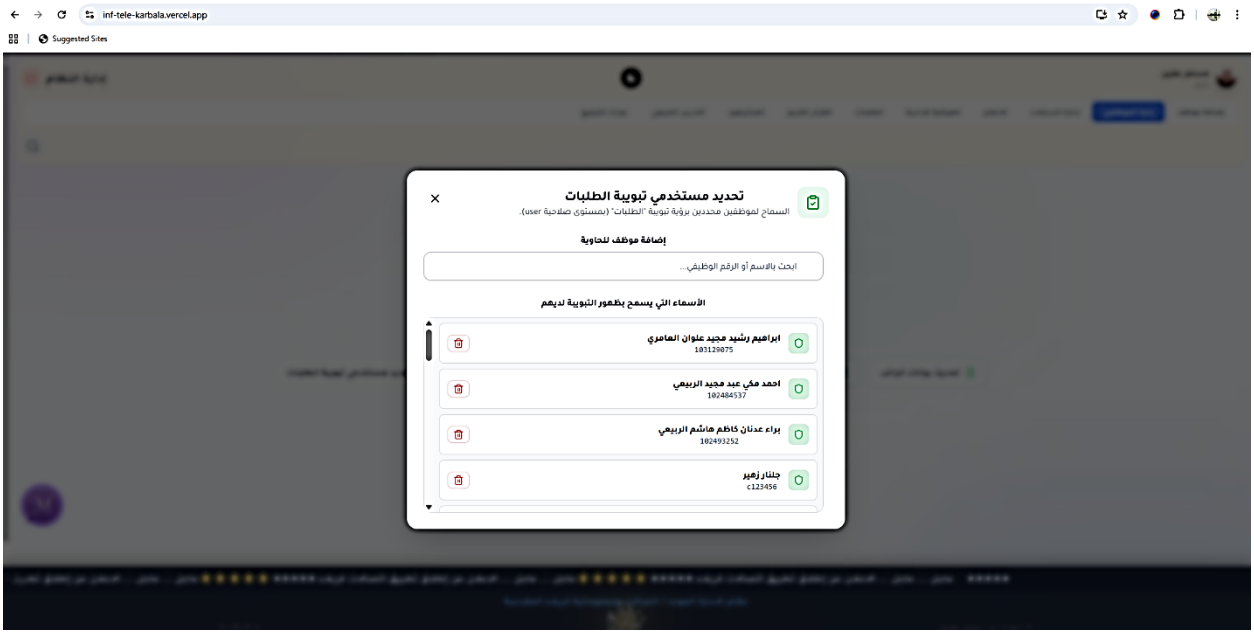





inf-tele-karbala.vercel.app
Suggested Sites
تحديث المعلومات الأساسية
حقن البيانات من ملف Excel إلى سجلات الموظفين
3
2
1
نطاق التحديث
ملف Excel
تحديث الكل
موظف محدد
اضغط لرفع الملف


inf-tele-karbala.vercel.app
Suggested Sites
المحدث العام
حقن بيانات Excel إلى أي جدول في النظام
1. رفع الملف واختيار الجدول
2. ربط الأعمدة
3. معاينة النتائج
4. التنفيذ
✓ اكتمال
1 اختر الجدول المستهدف
الملفات الشخصية
profiles
سجل واحد/موظف
السجلات المالية
financial_records
سجل واحد/موظف
السجلات السنوية
yearly_records
سنوي
تفاصيل كتب الشكر
thanks_details
تفصيلي (عدة سجلات)
تفاصيل اللجان
committees_details
تفصيلي (عدة سجلات)
تفاصيل العقوبات
penalties_details
تفصيلي (عدة سجلات)
تفاصيل الإجازات
leaves_details
تفصيلي (عدة سجلات)
2 رفع ملف Excel
انقر لاختيار ملف Excel
(.xlsx ,.xls)


inf-tele-karbala.vercel.app
Suggested Sites
صلاحيات الحقول
تحديد مستوى الصلاحية المطلوب لتعديل كل حقل مالي (1 للمالية، 2 للموارد البشرية، الخ..)
الاسم الكامل full_name
عام إعلام موارد بشرية مالية
اسم المستخدم username
عام إعلام موارد بشرية مالية
كلمة المرور password
عام إعلام موارد بشرية مالية
نوع الحساب (مشرف/موظف) role
عام إعلام موارد بشرية مالية
الرقم الوظيفي الموحد job_number
عام إعلام موارد بشرية مالية
رمز (IBAN) iban
عام إعلام موارد بشرية مالية
تاريخ اول تعيين first_hire_date
عام إعلام موارد بشرية مالية
القسم / الشعبة (التشكيل الإداري) department_id
عام إعلام موارد بشرية مالية
سجلات: كتب الشكر thanks
عام إعلام موارد بشرية مالية
سجلات: اللجان committees
عام إعلام موارد بشرية مالية
سجلات: العقوبات penalties
عام إعلام موارد بشرية مالية
تبوية المشرفون tab_supervisors
عام إعلام موارد بشرية مالية
تبوية التدريب الصيفي tab_training
عام إعلام موارد بشرية مالية
تبوية الطلبات tab_requests
عام إعلام موارد بشرية مالية
حفظ التغييرات
إلغاء


inf-tele-karbala.vercel.app
Suggested Sites
تحديد مستخدمي تبوية الطلبات
السماح لموظفين محددين برؤية تبوية "الطلبات" (بمستوى صلاحية user).
إضافة موظف للحاوية
ابحث بالاسم أو الرقم الوظيفي...
الأسماء التي يسمح بظهور التبوية لديهم
ابراهيم رشيد مجيد علوان العامري
103129075
احمد مكي عبد مجيد الربيعي
102484537
براء عدنان كاظم هاشم الربيعي
102493252
جلنار زهير
c123456

Notable: Supervisor-level access was bypassed by exploiting a client-side logic flaw that checks for a specific string in the full_name field — a check that can be trivially forged by any attacker.

5. Data Exfiltration Inventory

Data Category	Description	Scope
Personal Data	Full names, phone numbers, national ID card numbers	348 employees
Financial Data	International Bank Account Numbers (IBAN)	150+ employees
Operational Data	Job numbers, departments, hierarchy levels	Full organization
Security Credentials	Usernames and plaintext passwords	All accounts

6. Remediation & Recovery Plan

6.1 Immediate Actions (Within 24 Hours)

- **Enable RLS:** Execute ALTER TABLE profiles ENABLE ROW LEVEL SECURITY; on ALL database tables immediately.
- **Rotate API Keys:** Change both the Supabase Anon Key and Service Role Key without delay.
- **Revoke Secrets:** Reset the OneSignal App ID and all associated API keys.

6.2 Architectural Fixes (Short-Term)

- **Password Hashing:** Implement Bcrypt hashing for all stored passwords. Migrate existing plaintext passwords immediately.
- **Environment Isolation:** Move all API keys and secrets to Vercel Environment Variables; never expose them in frontend JavaScript bundles.
- **Server-Side Authorization:** Move all authorization logic from the React frontend to secure Backend functions or Supabase Edge Functions.

7. Conclusion

The Karbala Telecommunications Management System is currently in a state of total security compromise. The combination of exposed API keys, disabled database protection, client-side authorization, and plaintext password storage creates a scenario where any actor with basic technical knowledge can fully control, modify, or destroy all system data.

Immediate shutdown of the system is strongly recommended until all critical fixes outlined in this report are fully implemented and independently verified.

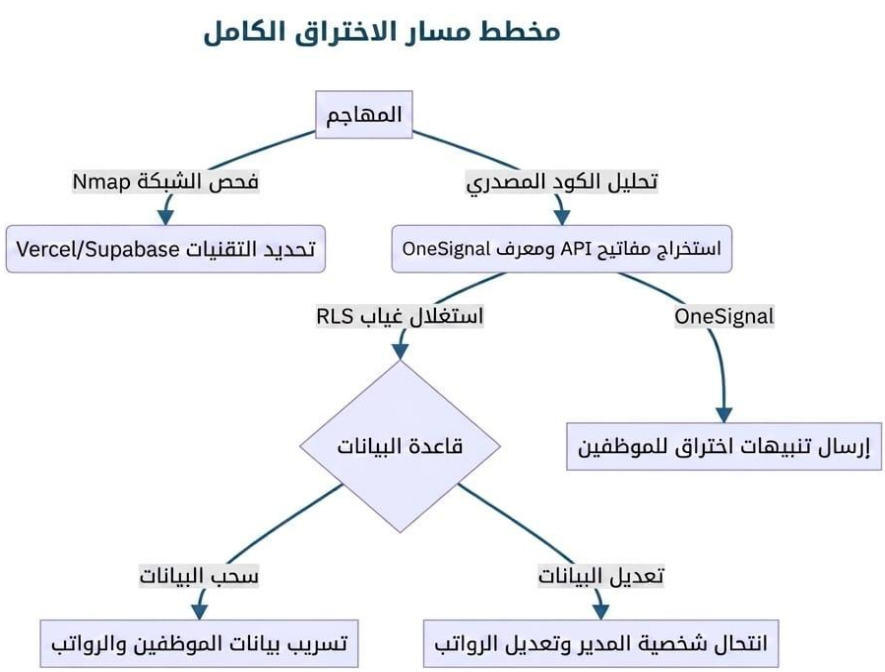
1- الملخص التنفيذي

هذا التقرير هو ناتج عملية فحص أمني شاملة. كشفت النتائج عن انهيار كامل في المنظومة الأمنية لنظام مديرية اتصالات كربلاء، حيث تمكّن فريقنا من الوصول إلى جميع مفاتيح الدخول إلى النظام وتسريب بيانات 348 موظفاً حساسة، تشمل: الرواتب، وأرقام الحسابات البنكية (IBAN)، وكلمات المرور المخزّنة دون تشفير. النظام متاح حالياً للاختراق والسيطرة الكاملة من أي جهة خارجية.

2- مخطط مسار الهجوم الكامل

سار الهجوم وفق منهجية متتالية متعددة المراحل:

- **مرحلة الاستطلاع:** تحليل ملفات حزمة JavaScript (JS) لاستخراج الأسرار المدمجة بداخلها.
- **مرحلة الاستخراج:** سحب قاعدة البيانات كاملةً باستغلال غياب حماية Row Level Security (RLS).
- **مرحلة تصعيد الصلاحيات:** الدخول إلى لوحات المستخدم والمشرف والمطوّر باستخدام بيانات الاعتماد النصية المكشوفة في التسريب.



3- النتائج التقنية التفصيلية والأدلة

3.1 الأسرار المدمجة في الكود وتسريب المعلومات

تمّ العثور على متغيرات البيئة الحساسة ومفاتيح API مدمجةً مباشرةً داخل حزمة JavaScript الأمامية (index-D05SJKk2.js). يُعدّ هذا انتهاكاً صريحاً لمبدأ الإدارة الآمنة للأسرار.

```
SUPABASE_URL:  "https://jvnjkqxpnhridlbczkgw.supabase.co"
SUPABASE_ANON_KEY: "sb_publishable_WSFpLJv1U6t-VezOuSWwZw_Dr8PvoyS"
ONESIGNAL_APP_ID:  "beae0757-7abe-46a8-b223-8f6c65e47fb5"
```

3.2 تجاوز حماية RLS الشاملة (وصول غير مصرّح به للقاعدة)

يفشل النظام في تطبيق قواعد Row Level Security على جداول Supabase. وباستخدام المفاتيح المسرَّبة، يستطيع أي مهاجم خارجي تنفيذ عمليات CRUD كاملة (إنشاء، قراءة، تعديل، حذف) على جداول 'profiles' و 'financial_records' دون أي مصادقة.

أمر إثبات المفهوم (PoC) — يجلب جميع السجلات الـ 348:

```
curl -X GET "https://jvnjkqxpnhridlbczkgw.supabase.co/rest/v1/profiles?select=*"  \
-H "apikey: sb_publishable_WSFpLJv1U6t-VezOuSWwZw_Dr8PvoyS" \
-H "Authorization: Bearer sb_publishable_WSFpLJv1U6t-VezOuSWwZw_Dr8PvoyS"
```

3.3 تخزين كلمات المرور بنص صريح (دون تشفير)

تُخزَّن كلمات المرور في قاعدة البيانات دون أي تجزئة (hashing) أو تشفير. وهذا يعني أن أي شخص يصل إلى قاعدة البيانات يستطيع فوراً استخدام بيانات الاعتماد لسرقة الهوية أو شنّ هجمات إضافية.

عيّنة من بيانات الاعتماد المسرَّبة (من سجلات مؤكدة):

الدور	كلمة المرور (مكشوفة)	اسم المستخدم	الاسم الكامل
مطوّر	654321	مسلم عقيل	مسلم عقيل عبدالحسن
مستخدم	106521	حيدر هاتف	حيدر هاتف عبدالحمزة
مستخدم	123456	جلنار زهير	جلنار زهير

4- مستويات تصعيد الصلاحيات المحققة

تم التحقق بنجاح من الوصول الكامل إلى جميع مستويات واجهات النظام:

- **مستوى المستخدم:** الوصول إلى الملفات الشخصية وطلبات الإجازات والبيانات المالية الفردية.
- **مستوى المشرف:** الوصول إلى نظرة عامة على الأقسام وإدارة الرواتب وسير عمل الموافقات.
- **مستوى المطوّر:** الوصول إلى إعدادات النظام ومحفّزات الإشعارات الفورية والتحكم في مخطط قاعدة البيانات.

ملاحظة: تم تجاوز الوصول إلى مستوى المشرف من خلال ثغرة منطقية في جانب العميل تتحقق من سلسلة نصية محددة في حقل الاسم الكامل — وهي فحص يمكن لأي مهاجم تزويره بسهولة.

5- جرد البيانات المسربة

النطاق	الوصف	فئة البيانات
348 موظفاً	الأسماء الكاملة وأرقام الهواتف وأرقام بطاقات الهوية	البيانات الشخصية
أكثر من 150 موظفاً	أرقام الحسابات المصرفية الدولية (IBAN)	البيانات المالية
المؤسسة كاملةً	الأرقام الوظيفية والهياكل التنظيمية ومستويات التسلسل الهرمي	البيانات التشغيلية
جميع الحسابات	أسماء المستخدمين وكلمات المرور بنص صريح	بيانات الاعتماد الأمنية

6- خطة المعالجة والتعافي

6.1 الإجراءات الفورية (خلال 24 ساعة)

- تفعيل RLS: تنفيذ الأمر ALTER TABLE profiles ENABLE ROW LEVEL SECURITY; على جميع الجداول فوراً.
- تدوير مفاتيح API: تغيير Supabase Anon Key و Service Role Key دون تأخير.
- إلغاء الأسرار: إعادة تعيين OneSignal App ID وجميع مفاتيح API المرتبطة به.

6.2 الإصلاحات المعمارية (المدى القصير)

- تجزئة كلمات المرور: تطبيق تجزئة Bcrypt لجميع كلمات المرور المخزّنة وترحيل كلمات المرور النصية الحالية فوراً.
- عزل متغيرات البيئة: نقل جميع مفاتيح API والأسرار إلى Vercel Environment Variables وعدم كشفها أبداً في حزم JavaScript الأمامية.
- تفويض جانب الخادم: نقل منطق التفويض من الواجهة الأمامية React إلى وظائف الخلفية الآمنة أو Supabase Edge Functions.

7- الخلاصة

يعاني نظام مديرية اتصالات كربلاء حالياً من حالة اختراق أمني شامل. تؤدي ثغرات المفاتيح المكشوفة وتعطيل حماية قاعدة البيانات والتفويض من جانب العميل وتخزين كلمات المرور النصية إلى سيناريو يمكن فيه لأي شخص يمتلك معرفة تقنية أساسية السيطرة الكاملة على بيانات النظام أو تعديلها أو تدميرها.

⚠يُوصى بشدة بإيقاف النظام فوراً حتى يتم تطبيق جميع الإصلاحات الحرجة الواردة في هذا التقرير والتحقق منها بشكل مستقل.